

Length Authority and Representation Canonicity at an SQIsign Verification Boundary

Dana Edwards

Version 1.0 preprint, 12 August 2026

PREPRINT — NOT PEER REVIEWED. The findings concern one pinned public implementation revision and a bounded x86 test matrix. SQIsign maintainers confirmed the intended API contracts, reported independently developed fixes in their development tree, reproduced the affected behavior, and authorized immediate publication.

Abstract

We study length authority and representation canonicity at the public verification boundary of the SQIsign implementation at revision `dd133d7aca576c361a270c8e6434832535b42ecc`. On 11 August 2026 the official remote `main` branch resolved to that revision, and a fresh same-machine replay exercised a six-authority matrix comprising parameter levels 1, 3, and 5 under the reference and Broadwell x86 implementations. Across both public verification paths, all 2,656 tested undersized inputs produced AddressSanitizer findings before a tested boundary repair; the repair converted all tested cases to clean pre-decode rejections. The detached verifier also accepted all 1,200 tested representations formed by appending one or sixteen declared bytes to 600 valid fixed-size KAT signatures. An exact-length guard rejected all such tested suffix aliases while preserving all 600 exact KAT signatures. Generic Lean theorems identify the structural boundary: accepted decoder fibers are injective exactly when accepted encodings are normalization fixed points, while the ordered x-only observable $(x(R), x(S), x(R - S))$ determines (R, S) only up to simultaneous negation. The results are bounded implementation and representation findings, not a forgery, key recovery, remote-code-execution result, deployment exploit, or defect in the mathematical security proof. The fresh replay packet commits the runner, environment, complete per-case records, representative raw logs, and a fail-closed content-addressed receipt. Following private disclosure, the maintainers reported that they had independently implemented equivalent boundary checks approximately one month earlier. They reproduced the affected behavior by reverting those checks and reported clean rejection without AddressSanitizer findings after restoring them. They also confirmed that exact equality is the intended detached-signature contract and authorized immediate publication. Their confirmation is independent maintainer evidence, but no maintainer raw logs or public fixing commit were available at this preprint’s cutoff.

Keywords. SQIsign; parser safety; signature representation; canonical encoding; AddressSanitizer; formal verification; Lean.

1 Introduction

A verification function receives bytes together with an asserted extent. A fixed-size decoder may safely consume those bytes only after the extent has been checked. This apparently mundane

ordering constraint is a security boundary: once a bare pointer enters a decoder, the evidence that the required bytes exist is no longer present in the decoder’s interface.

SQISign is a compact post-quantum signature scheme built from supersingular isogenies and quaternion arithmetic [3]. This paper develops a bounded case study for its public implementation repository [6]. It separates three questions that are easy to conflate:

1. Does every public verification path reject an undersized input before fixed-size decoding?
2. Does a detached signature’s declared length participate in the accepted representation, or is only a fixed prefix consumed?
3. When two byte strings decode to the same mathematical data, can both reach an accepting verifier state?

The first property is false throughout the complete tested undersized x86 matrix at the pinned revision. The second question yields accepted suffix aliases at the detached pointer/length interface. The third requires a more careful answer: a generic formal theorem shows that byte uniqueness depends on an accepted-normal-form property beyond mathematical object uniqueness.

Our contributions are deliberately narrow.

- We record a complete tested-domain falsification of pre-decode length authority for two public APIs across six x86 authorities.
- We record accepted overlong detached representations and distinguish this API-level fact from a strong-unforgeability conclusion.
- We evaluate a minimal boundary repair against undersized inputs, exact KAT signatures, and two suffix lengths, and record subsequent maintainer confirmation of both the intended contracts and an independently developed development-tree fix.
- We connect the implementation findings to generic normalization and x-only quotient formal sources while retaining their distinct build and provenance status, without claiming a formal refinement theorem for production SQISign.

2 Authority, evidence, and claim discipline

2.1 Frozen implementation authority

The audited authority is the repository `SQISign/the-sqisign` at the 40-hex revision

`dd133d7aca576c361a270c8e6434832535b42ecc`.

The recorded matrix covers parameter levels 1, 3, and 5, each under the reference and Broadwell x86 implementation. We make no claim about another revision, architecture, backend, API wrapper, or deployment. Live remote queries on 11 and 12 August 2026 resolved official `main` to this exact commit. These time-stamped equalities are kept separate from the frozen authority and do not conflict with the maintainers’ statement that the fixes were already present in a separate development tree.

2.2 Evidence classes

All quantitative claims in this preprint use a fresh end-to-end run from a clean official checkout rather than the exploratory discovery records. The fresh packet contains the exact runner and harnesses, GCC/ASan environment, all per-case records for the complete matrix, representative sanitizer and safe-return logs, and hashes for every generated artifact. Its normal and optimized validators agree. AddressSanitizer is the dynamic memory-error detector described by Serebryany et al. [5]. The packet closes the local-replay and dated-source gaps for the pinned revision; it is not an independent third-party reproduction.

On 12 August 2026, following private disclosure, the SQIsign team supplied a written maintainer confirmation. They stated that the two checks had been developed independently approximately one month before the report, reproduced the affected behavior after temporarily undoing those checks, and obtained clean rejections without AddressSanitizer findings after restoring them. This is an independent maintainer reproduction and contract confirmation, although the project does not possess their raw logs or development-tree commit. A sanitized correspondence summary and disclosure timeline accompany this preprint; the private email address and full message headers are not published.

No quantitative result in this preprint rests solely on a conversational or user-reported count. The evidence mapping and nearest nonclaim for the six headline claims appear in `claims_evidence.json`.

3 Length authority before fixed-size decoding

Let $s_1 = 148$, $s_3 = 224$, and $s_5 = 292$ denote the signature byte sizes in the three recorded parameter profiles. For each of two implementations and two public verification paths, the campaign called the API at every declared length $0, \dots, s_i - 1$. The zero-length case used a one-byte non-null allocation, separating the length contract from null-pointer behavior. The number of calls was therefore

$$2 \text{ APIs} \cdot 2 \text{ implementations} \cdot (148 + 224 + 292) = 2,656.$$

The two paths were the NIST-style `crypto_sign_open` interface and the detached `sqisign_verify` interface. At the pinned revision both paths allowed a bare signature pointer to reach fixed-size decoding before the provided length authorized the read.

Table 1: Complete recorded undersized-input matrix.

Variant	Calls	ASan findings	Clean pre-decode rejections
Pinned implementation	2,656	2,656	0
Tested repair	2,656	0	2,656

Observation 1 (Bounded length-authority defect). *For every input in the recorded undersized x86 matrix, the pinned implementation produced an AddressSanitizer finding rather than a clean pre-decode rejection. This falsifies the tested property that each public API rejects every undersized input before fixed-size signature decoding.*

This observation is an implementation-safety result under the recorded build and sanitizer configuration. It does not by itself establish remote code execution, confidentiality loss, or exploitability in any named deployment.

4 Detached suffix aliases

The detached verifier receives a signature pointer and a `siglen` argument. In the pinned implementation, the recorded source audit found that `siglen` did not govern entry into the fixed-size signature decoder. Consequently, the campaign evaluated each of 600 valid detached KAT signatures in three forms: exact length, one appended declared byte, and sixteen appended declared bytes.

The maintainers subsequently confirmed that exact equality is the intended contract for detached `siglen`. By contrast, the signed-message open path correctly admits `smilen >= SIGNATURE_BYTES`, because bytes following the fixed-size signature are the message. Its missing boundary condition was only the lower bound `smilen < SIGNATURE_BYTES`.

Table 2: Recorded detached-signature results.

Representation	Pinned accepted	Repaired accepted
Exact fixed-size signature	600/600	600/600
Exact signature plus one byte	600/600	0/600
Exact signature plus sixteen bytes	600/600	0/600

At the C API boundary, these are distinct declared byte representations with a common valid fixed-size prefix, message, and verification result. We call them *suffix aliases*. This terminology avoids silently assuming that a formal security experiment defines the signature domain as arbitrary length-delimited strings. If the formal domain contains only fixed-size signatures, the extra suffix may lie outside the mathematical signature rather than constitute a second signature in that experiment. Therefore Table 2 is not, by itself, a strong-unforgeability theorem or an existential forgery.

5 Boundary repair and maintainer confirmation

Our tested patch inserts two dominating guards before signature decoding. For the signed-message path it rejects when `smilen < SIGNATURE_BYTES`, setting the output message length to zero. For detached verification it rejects unless `siglen == SIGNATURE_BYTES`.

The recorded repaired matrix supplies three complementary checks:

1. all 2,656 undersized calls became clean rejections with no recorded AddressSanitizer finding;
2. all 600 exact KAT signatures remained accepted; and
3. all 1,200 tested suffix aliases were rejected.

This is closure over the complete tested x86 matrix, not a proof about all C callers or all parser defects. The maintainers confirmed that these are the intended policies. They also reported that their team had independently added equivalent pre-decode checks approximately one month before receiving this report, and that improved regression tests would accompany the Round 3 release. Because their development-tree source was not public at the preprint cutoff, we do not claim our patch is byte-identical to theirs or identify a public fixing commit.

6 Why decoder aliasing is not enough

Suppose two byte strings decode to the same internal object. This decoder alias alone does not establish an accepted representation collision: an independent algebraic check may reject the common decoded object in both cases. Conversely, the suffix experiment in Section 4 directly establishes accepted aliases at the detached pointer/length interface because the two distinct declared byte strings receive the same accepting verdict.

The distinction is therefore between equality in a decoder fiber and injectivity of the decoder restricted to accepted inputs. The next section formalizes the exact extra condition needed to pass from the former to the latter. We make no universal claim about fixed-length SQIsign serialization.

7 Structural canonicity theorems

The accompanying Lean development separates mathematical fibers from byte normal forms.

7.1 Normalization fixed points

Let $D : B \rightarrow O$ decode byte representations, $E : O \rightarrow B$ encode objects, and $V : O \rightarrow \{\text{true}, \text{false}\}$ verify objects. Define

$$N(b) = E(D(b)), \quad A(b) = V(D(b)).$$

Assume $D(E(o)) = o$ for every object o .

Proposition 1 (Accepted-fiber normalization criterion). *The decoder is injective on accepted fibers if and only if every accepted byte string is a fixed point of N . Moreover, any accepted b with $N(b) \neq b$ immediately yields two distinct accepted representations, b and $N(b)$, with equal decoded objects.*

Proof idea. Normalization preserves decoded objects by the section law and therefore preserves acceptance. Accepted-fiber injectivity forces $N(b) = b$. Conversely, two accepted bytes in one decoder fiber have one common normal form; if both are fixed points, they are equal. The frozen Lean 4 source [2] `CanonicalNormalization.lean` contains this generic proof without placeholders. Its exact frozen source hash was freshly rebuilt with Lean 4.19.0 and the recorded Mathlib revision on 11 August 2026. The fresh axiom audit reports no axioms for the two normalization theorems used here. $\square$

This proposition captures the inner ground for canonical acceptance: accepted bytes must already be the selected normal form. It does not instantiate the pinned SQIsign decoder or verifier.

7.2 The ordered x-only quotient

For points on an affine Weierstrass curve over a field, define

$$X(R, S) = (x(R), x(S), x(R - S)),$$

using a separate value for the point at infinity. The classical elliptic x -line is a sign quotient; related quotient geometry appears in [1, 4]. The accompanying Lean development checks the exact ordered-pair statement:

$$X(R', S') = X(R, S) \iff (R', S') = (R, S) \text{ or } (R', S') = (-R, -S).$$

Thus the induced map from the simultaneous-sign quotient is injective. The third coordinate synchronizes the otherwise independent endpoint signs via the identities $S = R - (R - S)$ and $R = (R - S) + S$.

This is a mathematical object theorem. Byte uniqueness additionally needs a production refinement showing that every accepted serialization is the chosen orbit normal form. No such refinement theorem is claimed here.

8 Security interpretation and limitations

The evidence supports two distinct bounded conclusions. First, supplied lengths did not dominate fixed-size decoding for either tested verification path. Second, detached verification accepted tested suffix aliases at its pointer/length boundary. Neither conclusion depends on treating the generic x-only quotient theorem as a production verifier theorem.

The nearest likely overclaims are expressly excluded:

- no invalid signature for a new message was produced;
- no secret key was recovered;
- no remote-code-execution or deployment-specific exploitability claim is made;
- no flaw in the mathematical SQIsign security proof is established;
- no universal serialization-canonicity theorem is established;
- no EUF-CMA or SUF-CMA conclusion follows without fixing and analyzing the exact formal representation domain;
- neither our tested patch nor the reported development-tree fix is claimed to eliminate every parser defect; and
- the maintainers' development-tree fix is reported correspondence evidence, not a source-level audit of a public fixing commit.

The complete matrix was rerun by the published end-to-end runner, with complete case records and representative raw logs bound by the fresh receipt. The maintainer response adds independent human reproduction and contract confirmation, but not their raw logs or development-tree source.

9 Coordinated-disclosure timeline

The report was sent privately to the SQIsign team on 11 August 2026. On 12 August, the team acknowledged it, confirmed both intended length contracts, reported the independently developed development-tree fixes and reproduction described above, and stated that SQIsign is a reference implementation without a responsible-disclosure policy. The team explicitly authorized immediate publication, including publication as a public issue, and said the fixes would ship in the forthcoming Round 3 release.

At the preprint cutoff, the public `main` branch still resolved to the affected revision. We therefore distinguish three states: the frozen public revision tested here; the maintainer-reported development-tree repair; and the future public fixing revision. This chronology avoids both implying that the report caused a fix developed earlier and implying that an unpublished repair was already present in the audited public source.

10 Reproducibility map

The release directory is designed to stand alone as a GitHub or Zenodo artifact and is available at <https://github.com/TheDarkLightX/sqisign-verification-boundary>. Its public artifact map is as follows:

- tested source patch: `patches/sqisign-dd133d7-h7-length-guards.patch`;
- fresh full-matrix runner, case records, representative raw logs, and receipt: `research/h7_completion_2026_08_11/`;
- formal normalization theorem: `research/h7_completion_2026_08_11/lean/IsogenyCrypto/H7/CanonicalNormalization.lean`;
- formal x-only fiber and quotient theorems: `research/h7_completion_2026_08_11/lean/IsogenyCrypto/H7/XCoordinateFiber.lean` and `research/h7_completion_2026_08_11/lean/IsogenyCrypto/H7/XOnlyQuotient.lean`;
- exact-source Lean 4.19.0 build and axiom receipt: `research/h7_completion_2026_08_11/lean/validation_receipt.json`;
- sanitized maintainer confirmation and disclosure chronology: `MAINTAINER_CONFIRMATION.md` and `DISCLOSURE_TIMELINE.md`.

Exact git refs, evidence classes, selected hashes, and nonclaims for the five headline claims are machine-readable in `claims_evidence.json`.

Acknowledgments and AI-use disclosure

The author thanks Décio and the SQIsign team for their prompt response, independent reproduction, contract clarification, and disclosure guidance. OpenAI Codex agents assisted with exploratory analysis, test and validation code, evidence organization, and drafting. Their outputs were treated as untrusted candidate material and checked against frozen source, replayable experiments, and machine-checked proof artifacts. Dana Edwards reviewed and approved the claims, experiments, limitations, and final text and takes responsibility for the work. No AI system is an author.

References

- [1] Craig Costello and Benjamin Smith. Montgomery curves and their arithmetic. arXiv:1703.01863, 2017.
- [2] Leonardo de Moura and Sebastian Ullrich. The Lean 4 theorem prover and programming language. In *Automated Deduction – CADE 28*, pages 625–635, 2021.
- [3] Luca De Feo, David Kohel, Antonin Leroux, Christophe Petit, and Benjamin Wesolowski. SQIsign: Compact post-quantum signatures from quaternions and isogenies. Cryptology ePrint Archive, Paper 2020/1240, 2020.
- [4] David Kohel. Arithmetic of split kummer surfaces: Montgomery endomorphism of edwards products. arXiv:1601.03680, 2016.
- [5] Konstantin Serebryany, Derek Bruening, Alexander Potapenko, and Dmitriy Vyukov. AddressSanitizer: A fast address sanity checker. In *2012 USENIX Annual Technical Conference (USENIX ATC 12)*, pages 309–318, 2012.
- [6] SQIsign implementation repository. <https://github.com/SQIsign/the-sqisign>. Implementation authority audited at revision dd133d7aca576c361a270c8e6434832535b42ecc.